

Florida Critical Infrastructure Cybersecurity Intelligence

Situational Awareness Bulletin Bulletin #03-26

Cyber Threat Outlook

Florida's critical infrastructure environment is currently navigating a high-intensity threat landscape defined by the strategic exploitation of legacy edge devices and a pivot toward "identity-first" attack vectors. Advanced persistent threat (APT) groups, such as Salt Typhoon and TGR-STA-1030, are increasingly utilizing eBPF-based rootkits and "living off the land" techniques to establish stealthy Kernel-level persistence within unmanaged network hardware. Simultaneously, the 84% surge in attacks targeting operational technology (OT) protocols like Modbus indicates that adversaries are moving beyond corporate IT to target core industrial processes directly. Florida operators should anticipate heightened targeting of third-party payment gateways and decentralized energy assets, which have already demonstrated the potential for cascading operational disruptions. Prioritizing the retirement of end-of-support (EOS) peripherals and implementing phishing-resistant multi-factor authentication (MFA) are the most critical near-term actions to mitigate these evolving systemic risks.

Confidence - High

Executive Summary

- **All Sectors:** CISA added critical vulnerabilities in Telnet (CVE-2026-24061) and SolarWinds Web Help Desk (CVE-2025-40551) to the Known Exploited Vulnerabilities (KEV) Catalog. Federal directives (BOD 26-02) now mandate decommissioning legacy edge devices to close primary entry points for state-sponsored actors.
- **Commercial Facilities:** The ShinyHunters group compromised Panera Bread via a phishing-led Microsoft Entra single sign-on (SSO) breach, leaking 5.1 million records and signaling a strategic shift toward targeting identity providers.
- **Communications:** Critical remote code execution (RCE) vulnerabilities in IDIS Cloud Manager and Sangoma FreePBX pose immediate risks, while the Salt Typhoon campaign continues targeting telecommunications infrastructure through outdated hardware.
- **Critical Manufacturing:** An 84% surge in OT protocol attacks, primarily targeting Modbus and EtherNet/IP, highlights an increased adversary focus on disrupting internal manufacturing networks.
- **Energy:** Coordinated destructive attacks targeting over 30 facilities in Poland utilized DynoWiper malware to brick hardware, posing a direct threat to Florida's decentralized solar and wind assets that use similar configurations.

- **Financial Services:** A ransomware attack on BridgePay Network Solutions caused nationwide payment gateway outages, directly impacting online payment portals for multiple Florida municipalities.
- **Government Facilities:** Ivanti Endpoint Manager Mobile zero-days were exploited to breach government entities, and the TGR-STA-1030 group targeted 70 global entities using custom Linux rootkits.
- **Healthcare and Public Health:** Health-ISAC issued warnings for potential digital retaliation against U.S. healthcare systems following geopolitical tensions, urging immediate prioritization of legacy medical device security.
- **Information Technology:** Supply chain attacks targeting Notepad++ and the emergence of Adversary-in-the-Middle (AitM) frameworks like DKnife are being used to hijack traffic and deliver secondary backdoors.
- **Water and Wastewater Systems:** Third-party breaches at BridgePay disrupted water-bill payments in several cities, reflecting a systemic dependency for Florida utilities.

All Sectors

“Telnet Flaw: 800,000 Servers at Risk Amid Active Authentication Bypass Attacks” CISA added a critical authentication bypass vulnerability in the GNU InetUtils telnetd server (CVE-2026-24061) to its Known Exploited Vulnerabilities (KEV) Catalog on January 26, 2026. The flaw allows remote attackers to gain root-level access by simply sending the string "-f root" as a user environment variable. Approximately 800,000 Telnet instances remain internet-exposed globally, with 50,000 located in the United States. This legacy protocol is an "absolute gift" for nation-state actors seeking persistence on OT systems, necessitating that Florida CI operators either disable Telnet immediately or restrict network access to trusted clients.

“Fortinet Mitigates Critical FortiCloud SSO Zero-Day Exploited in Firewall Attacks”

Fortinet confirmed on January 27, 2026, a critical authentication bypass zero-day (CVE-2026-24858) affecting the FortiCloud Single Sign-On (SSO) feature. The flaw allowed attackers with a registered device to log into other customers' FortiGate, FortiManager, and FortiAnalyzer devices to create rogue administrator accounts and exfiltrate configuration files. Fortinet took the emergency step of temporarily disabling the service globally and now blocks logins from devices running vulnerable firmware. Florida organizations utilizing Fortinet's cloud management must upgrade to the latest firmware to restore SSO functionality and reduce intrusion risks.

“FBI Launches Operation Winter SHIELD to Counter Escalating Cyber Threats” The Federal Bureau of Investigation (FBI) launched "Operation Winter SHIELD" (Securing Homeland Infrastructure by Enhancing Layered Defense) on January 29, 2026. This 10-week campaign highlights the most effective defensive measures to reduce risk across critical infrastructure sectors. Key priorities include adopting phishing-resistant authentication, managing third-party risks, and decommissioning end-of-life technology on a defined schedule.

Florida organizations should utilize this roadmap to validate their current security posture against known nation-state and criminal methodologies.

“Glassworm Malware Targets Open VSX Registry in Novel Supply Chain Attack” A new supply chain campaign involving the "Glassworm" malware has been detected targeting the Open VSX Registry, an open-source alternative to the VS Code Marketplace. The malware is embedded in legitimate-looking extensions to establish a persistent backdoor for further lateral movement into corporate environments. This attack strategy materially changes defensive priorities by highlighting the risk of using unvetted third-party extension registries.

“Asian State-Backed Group TGR-STA-1030 Breaches 70 Government, Infrastructure Entities” A sophisticated state-aligned cyber espionage group tracked as TGR-STA-1030 (aka UNC6619) has compromised government and critical infrastructure organizations across 37 countries in the past year. The group utilizes a custom toolset including the "Diaoyu Loader," which employs a dual-stage execution guardrail requiring specific hardware resolutions and environmental files (e.g., "pic1.png") to thwart automated sandbox analysis. On Linux systems, the actors deploy a rootkit dubbed "ShadowGuard" that leverages the Extended Berkeley Packet Filter (eBPF) to run sandboxed code inside the kernel for persistence. This activity demonstrates significant targeting of finance and mining sectors, highlighting the need for Florida operators to monitor for specific Tactics, Techniques, and Procedures (TTPs) related to eBPF-based persistence and custom malware loaders.

“CISA orders federal agencies to patch exploited SolarWinds bug by Friday” On February 3, 2026, CISA added CVE-2025-40551 (CVSS 9.8) to the KEV Catalog. This vulnerability involves the deserialization of untrusted data in SolarWinds Web Help Desk, allowing unauthenticated attackers to execute arbitrary commands on the host machine. SolarWinds issued fixes in version 2026.1, which also address five additional critical vulnerabilities discovered during the same research cycle. This product is a staple in Florida’s government and municipal information technology (IT) sectors.

“CISA Adds Two Known Exploited Vulnerabilities to Catalog” On February 5, 2026, the CISA added CVE-2026-24423 to the KEV Catalog. This vulnerability impacts SmarterTools SmarterMail versions prior to Build 9511. The flaw exists in the ConnectToHub Application Programming Interface (API) method, which fails to implement proper authentication. Remote attackers can leverage this to point the instance toward a malicious server, facilitating Server-Side Request Forgery (SSRF) and arbitrary Operating System (OS) command execution. Florida entities in the education and government sectors frequently utilize SmarterMail for local communication hosting, making this a high-priority patch for in-state organizations.

“CISA orders feds to disconnect unsupported network edge devices” On February 5, 2026, CISA issued Binding Operational Directive (BOD) 26-02. The directive mandates that Federal Civilian Executive Branch (FCEB) agencies identify and remove all End-of-Support (EOS) edge devices, such as firewalls, routers, and load balancers. These devices no longer receive security patches or firmware updates, making them primary targets for nation-state actors to establish persistence and "live off the land" within critical networks. For Florida CI operators, particularly in the energy and water sectors, these legacy edge devices represent a significant security gap that can be exploited to bypass perimeter defenses.

“Forescout reports global cyberattacks spread wider in 2025, with more distributed and costly threats emerging in 2026” Forescout Research’s analysis of over 900 million attacks indicates a massive expansion of exploitation across IT, IoT, and OT environments. Attacks using OT protocols rose by 84%, with Modbus (57%) and Ethernet/IP (22%) being the most targeted. Attackers are increasingly abusing cloud services and legitimate infrastructure, with 71% of exploited vulnerabilities falling outside the CISA KEV Catalog. The report highlights a trend of attackers targeting edge devices and unmanaged assets to facilitate lateral movement.

All Sectors - Recommendations:

- **Disable legacy protocols:** Immediately identify all internet-facing instances of Telnet and replace them with secure alternatives like SSH to prevent authentication bypass attacks.
- **Decommission end-of-life hardware:** Conduct a comprehensive audit of all network edge devices and remove any hardware that has reached end-of-support status to eliminate unpatchable entry points.
- **Implement phishing-resistant MFA:** Transition organizational authentication systems to hardware-based tokens or FIDO2-compliant methods to thwart credential theft and SSO hijacking.
- **Patch high-priority management tools:** Prioritize the immediate update of SolarWinds Web Help Desk to version 2026.1 and SmarterMail to Build 9511 to remediate exploited RCE and SSRF vulnerabilities.
- **Enhance OT protocol monitoring:** Deploy network monitoring solutions capable of inspecting industrial protocols like Modbus and Ethernet/IP for anomalous command sequences and unauthorized access.

Chemical Sector

No sector-specific incidents, advisories, or tactically relevant reporting were identified during this biweekly reporting period

Communications Sector

“Claroty Team82 Reveals Critical RCE Vulnerability in IDIS Cloud Manager Viewer”

Researchers at Claroty's Team82 unit discovered a critical remote code execution (RCE) vulnerability (CVE-2025-12556) in the IDIS Cloud Manager (ICM) Viewer, widely used in the communications sector. The flaw allows an attacker to escalate beyond the browser sandbox and achieve code execution on the host machine if a user clicks a malicious link. This "1-click" vulnerability allows attackers to use the compromised host as a jumping-off point for lateral movement into surveillance networks. Florida operators using IDIS surveillance systems should upgrade to v1.7.1 immediately or uninstall the ICM Viewer.

“FCC Warns Telecommunications Providers of Rising Ransomware and Extortion Threats”

The Federal Communications Commission (FCC) issued an advisory on February 2, 2026, warning telecommunications providers of an increase in targeted ransomware and extortion campaigns. These attacks increasingly focus on disrupting 5G infrastructure and cell tower operations to force higher ransom payments. Florida relevance includes the state's heavy reliance on resilient communications for emergency management and the high concentration of major telecommunications providers operating in the region.

“CISA Adds Four Known Exploited Vulnerabilities to Catalog” Between February 3 and February 5, 2026, CISA added high-risk vulnerabilities impacting Sangoma FreePBX (CVE-2019-19006 and CVE-2025-64328) to the KEV Catalog. These flaws allow for improper authentication and Operating System (OS) command injection. These products are common in Florida's small-to-medium utility and municipal environments. Attackers are exploiting these flaws to gain persistent access to internal telephony systems.

“Norway accuses China's Salt Typhoon of espionage attacks” The Norwegian Police Security Service confirmed that the state-sponsored group Salt Typhoon breached multiple Norwegian organizations by exploiting vulnerable network devices. This marks an expansion of the campaign previously targeting U.S. and Canadian telecommunications infrastructure. The attackers utilize known vulnerabilities in outdated edge devices to establish long-term surveillance capabilities and intercept communications.

Communications Sector - Recommendations:

- Patch systems: Update IDIS Cloud Manager Viewer to v1.7.1 immediately to remediate the critical remote code execution vulnerability.
- Implement MFA: Implement phishing-resistant multi-factor authentication (MFA) for all administrative access to 5G management consoles and telephony systems.
- Upgrade systems: Decommission end-of-support (EOS) and outdated edge devices to prevent long-term surveillance by actors like Salt Typhoon.

- Audit vendors: Regularly audit third-party managed service provider (MSP) and remote access permissions to core telephony infrastructure.
- Create offline backups: Establish offline, immutable backups for critical dispatch and communication configurations to ensure recovery from targeted ransomware events.

Commercial Facilities Sector

“Panera Bread Microsoft Entra SSO Breach: ShinyHunters Leak 5.1 Million Customer Records” In late January 2026, major retail and food service entities, including Panera Bread, disclosed significant data breaches impacting approximately 5.1 million unique accounts. The attackers, identified as the ShinyHunters group, gained access by compromising Microsoft Entra Single Sign-On (SSO) codes through sophisticated vishing (voice phishing) campaigns. This incident indicates a strategic shift where attackers target the identity provider to gain broad access to corporate document repositories. For Florida CI managers, this highlights a systemic risk in "identity-first" security models where a single successful social engineering attempt can grant an attacker broad access to sensitive data.

Commercial Facilities Sector - Recommendations:

- Restrict SSO administrative access: Apply the principle of least privilege to identity provider (IdP) configurations and monitor for unusual login patterns from unmanaged devices.
- Audit cloud SaaS permissions: Regularly review access controls within cloud environments to ensure that a single compromised account cannot move laterally to high-value customer databases or document repositories.
- Monitor for credential stuffing: Utilize breach notification services to cross-check exposed employee and customer credentials against internal systems to proactively prevent account takeover attacks.

Critical Manufacturing Sector

“CISA Issues Multiple ICS Advisories for Rockwell and Siemens Products” CISA released multiple advisories in early 2026 regarding high-severity vulnerabilities in Rockwell Automation and Siemens industrial controllers. Exploits could allow unauthenticated remote attackers to cause denial-of-service (DoS) conditions or achieve privilege escalation in OT environments. These products are widely deployed in Florida’s manufacturing and energy sectors, necessitating immediate firmware reviews.

“Critical Kiloview Vulnerabilities Allow Attackers to Gain Full Administrative Control”

Researchers identified critical vulnerabilities in Kiloview video encoding and distribution hardware used extensively in industrial control and critical manufacturing environments. These

flaws allow unauthenticated remote attackers to bypass security controls and gain full administrative access to affected devices. Florida manufacturers using these encoders for remote monitoring should prioritize immediate firmware updates or isolate these devices from public-facing networks.

Critical Manufacturing Sector - Recommendations:

- Isolate remote monitoring hardware: Ensure Kiloview video encoders are not accessible via the public internet and are placed behind a secure VPN or firewall.
- Implement OT-specific monitoring: Deploy security solutions capable of inspecting Modbus and EtherNet/IP traffic to detect unauthorized reconnaissance or anomalous command sequences.
- Enforce network segmentation: Utilize internal firewalls and VLANs to restrict lateral movement between IT and OT networks, specifically focusing on "East-West" traffic control.
- Conduct regular asset discovery: Periodically scan OT environments to identify unmanaged or "shadow" assets that may be running vulnerable firmware.

Dams Sector

No sector-specific incidents, advisories, or tactically relevant reporting were identified during this biweekly reporting period

Defense Industrial Base Sector

No sector-specific incidents, advisories, or tactically relevant reporting were identified during this biweekly reporting period

Emergency Services Sector

No sector-specific incidents, advisories, or tactically relevant reporting were identified during this biweekly reporting period

Energy Sector

“Poland Power Grid Attack Targets Distributed Energy Facilities with Destructive Malware” A sophisticated and coordinated cyberattack, attributed with moderate confidence to the Russian-linked threat group Sandworm (tracked by Dragos as Electrum), targeted approximately 30 distributed energy resource (DER) facilities across Poland on December 29, 2025. While the attack occurred just outside the current window, new technical reporting released on January 28, 2026, revealed that attackers utilized "DynoWiper" malware to brick field-level hardware, including Hitachi RTUs and Mikronika controllers. The actors gained

initial access via internet-facing FortiGate firewalls lacking MFA and utilized automated "IP-ascending" targeting to scale the compromise. Florida relevance is extremely high given the state's growing reliance on decentralized solar and wind assets, which often use similar standardized OT configurations.

“Pro-Russian Hacker Alliance Issues Large-Scale Attack Warning Against Denmark” A pro-Russian hacker alliance known as "Russian Legion" issued an imminent threat of large-scale cyberattacks against Danish energy infrastructure on February 3, 2026. The group demanded the withdrawal of Danish military aid to Ukraine, warning that initial Distributed Denial-of-Service (DDoS) disruptions would escalate into destructive intrusions targeting power grid stability. This activity follows a pattern of "OpDenmark" campaigns and reflects a strategic shift toward targeting decentralized energy resources to cause regional instability. Florida relevance is significant as these campaigns serve as a precursor for TTPs that may be turned against U.S. grid assets during periods of heightened geopolitical tension

“Energy and Utilities Cyber Threats Escalate as Ransomware and APT Activity Rise” A Cyfirma report released on February 4, 2026, details a 63.6% increase in ransomware victims within the energy and utilities sector over the previous quarter. The report highlights that the sector featured in 43% of all observed Advanced Persistent Threat (APT) campaigns in early 2026, driven primarily by China-linked groups (such as Volt Typhoon and Stone Panda) and Russian financially motivated syndicates. Primary attack vectors involve the exploitation of web applications and legacy operating systems. This elevated threat level directly impacts Florida grid operators, who are facing increasingly coordinated efforts to breach the perimeter for both financial extortion and strategic reconnaissance.

“Romania’s oil pipeline operator Conpet targeted in cyberattack as Qilin alleges 1TB data breach” On February 4, 2026, the Qilin ransomware group claimed responsibility for a cyberattack on Conpet, a national oil pipeline operator. While Supervisory Control and Data Acquisition (SCADA) systems remained functional, the attackers successfully disrupted corporate IT and allegedly exfiltrated 1 Terabyte (TB) of sensitive data. This incident follows a pattern of Ransomware-as-a-Service (RaaS) groups targeting infrastructure operators to exert pressure via data leaks.

Energy Sector - Recommendations:

- Use MFA and VPN: Implement phishing-resistant multi-factor authentication (MFA) for all internet-facing firewalls and Virtual Private Network (VPN) gateways to prevent initial access via credential theft.
- Harden systems: Harden field-level Remote Terminal Units (RTUs) and controllers by disabling default credentials and restricting network access to trusted management subnets.

- Adjust security tools: Configure security tools to detect "IP-ascending" internal scans and file-wiping behaviors characteristic of destructive malware like DynoWiper.
- Segregate networks: Isolate decentralized solar and wind management networks from the primary corporate network to contain lateral movement during an intrusion.
- Patch and harden: Prioritize patching and hardening of public-facing web applications to mitigate the 63.6% rise in ransomware and APT activity targeting the sector.

Financial Services Sector

“Payments platform BridgePay confirms ransomware attack behind outage” On February 7, 2026, payment platform BridgePay Network Solutions confirmed that a nationwide service disruption was the result of a ransomware attack. The incident impacted the company's payment gateway, causing outages for various municipalities and commercial entities. Multiple Florida municipalities reported outages in their online payment portals as a direct result of this third-party breach.

Financial Services Sector - Recommendations:

- Develop manual processing contingencies: Establish and document "break-glass" procedures to maintain critical revenue collections during third-party gateway outages.
- Validate third-party SLAs: Review and update contracts with payment integrators to ensure specific requirements for rapid incident notification and forensic transparency.
- Implement redundant payment methods: Diversify payment options, such as ACH or secondary gateway providers, to mitigate the operational impact of a single-point-of-failure breach.
- Audit service provider access: Regularly review and restrict the permissions granted to third-party payment integrations within organizational networks.
- Monitor for downstream fraud: Enhance monitoring for unusual financial activity or customer support inquiries that may follow a major payment-enabler disruption.

Food and Agriculture Sector

No sector-specific incidents, advisories, or tactically relevant reporting were identified during this biweekly reporting period

Government Facilities Sector

“European Commission Hit by Mobile Management Data Breach via Ivanti Flaws” The European Commission confirmed on January 30, 2026, a cyberattack on its central mobile device management (MDM) infrastructure that may have exposed staff personal details. The incident coincides with critical code-injection vulnerabilities in Ivanti endpoint manager mobile (EPM) mobile (EPM) mobile (EPM).

(CVE-2026-1281 and CVE-2026-1340), which grant unauthenticated remote attackers full control over affected servers. While the Commission cleaned its systems within nine hours, similar attacks hit government bodies in the Netherlands and Finland. Florida government agencies should treat MDM infrastructure as critical and apply patches for Ivanti EPMM to prevent user account hijacking.

“CISA Orders Federal Agencies to Strengthen Edge Device Security Amid Rising Cyber Threats” The CISA issued Binding Operational Directive (BOD) 26-02 on February 5, 2026, mandating that Federal Civilian Executive Branch (FCEB) agencies identify and remediate end-of-support (EOS) edge devices. These public-facing devices, including firewalls, routers, and VPN gateways, are increasingly exploited by nation-state actors because they no longer receive critical security updates. Agencies must inventory all active edge devices by May 5, 2026, and decommission unsupported hardware within 18 months. This directive carries high Florida relevance due to the potential for cascading risks into state networks that interface with federal agencies and the common use of these edge technologies across local government facilities.

“Asian Cyber Espionage Campaign Breached 37 Countries” A state-aligned hacking group, tracked as TGR-STA-1030 (or "Shadow Campaigns"), compromised 70 organizations across 37 countries, targeting government ministries, law enforcement, and trade agencies. The group utilizes a custom Linux rootkit named "ShadowGuard" to hide malicious processes and maintain persistence. Attacks often begin with phishing emails referencing internal reorganizations or trade policy, leading to the deployment of Cobalt Strike and the "Diaoyu" loader.

“0apt Ransomware Attack on Harbor Port Authority” The ransomware group 0apt attacked the Harbor Port Authority, compromising sensitive data including container tracking logs, security protocols, and duty logs. The breach threatens critical maritime infrastructure operations. The group creates persistence mechanisms and exfiltrates data prior to encryption.

Government Facilities Sector - Recommendations:

- Patch CVEs: Immediately apply critical patches for Ivanti EPMM to remediate RCE vulnerabilities and prevent unauthenticated control of mobile device management infrastructure.
- Inventory edge devices: Conduct a comprehensive inventory of all active edge devices by May 5, 2026, to identify and prioritize the decommissioning of EOS hardware as mandated by federal directives.
- Implement MFA: Implement phishing-resistant MFA and conduct targeted training sessions regarding social engineering lures that reference internal reorganizations or trade policies.

- Invest in security tools: Deploy advanced endpoint detection tools capable of identifying kernel-level anomalies and hidden processes characteristic of custom Linux rootkits like "ShadowGuard."

Healthcare and Public Health Sector

“Health-ISAC Braces for Digital Retaliation Against U.S. Critical Infrastructure” The Health Information Sharing and Analysis Center (Health-ISAC) warned on February 2, 2026, of potential digital retaliation from Russian and Iranian groups targeting American healthcare systems. The warning follows heightened geopolitical tensions and underscores the vulnerability of the healthcare sector to nation-state-sponsored disruptive attacks. Organizations are urged to prioritize the identification of legacy medical devices and enhance software supply chain security. Florida's high density of healthcare providers makes this a critical situational awareness item for maintaining continuity of care during periods of increased geopolitical friction.

Healthcare and Public Health Sector - Recommendations:

- Prioritize legacy device lifecycle management: Maintain an accurate inventory of all technically obsolete medical devices and implement proactive lifecycle management to mitigate vulnerabilities in hardware that no longer receives security updates.
- Enhance third-party and vendor oversight: Conduct rigorous cybersecurity risk assessments for all mission-critical third-party vendors and managed service providers, focusing on their access to internal clinical systems.
- Conduct clinical continuity testing: Routinely test emergency preparedness and clinical continuity plans specifically for extended technology outages affecting patient care or administrative scheduling.

Information Technology Sector

“Active Exploitation of Authentication Bypass in FortiCloud Single Sign-On” On January 28, 2026, Fortinet confirmed the ongoing exploitation of CVE-2026-24858, a critical authentication bypass vulnerability in FortiCloud Single Sign-On (SSO). This flaw allows unauthenticated remote attackers to gain administrative access to managed Fortinet devices by bypassing primary authentication controls. Many Florida healthcare networks and educational institutions rely on Fortinet for perimeter security, making this a high-relevance threat. Active exploitation suggests that threat actors are using this access to disable security logging and establish persistent backdoors within critical networks.

“Dozens of Global Companies Hacked via Cloud Credentials from Infostealer Infections” A threat actor known as "Zestix" (aka Sentap) was identified in early February 2026 auctioning

corporate data stolen from platforms including ShareFile and Nextcloud. The actor utilizes valid credentials harvested by Infostealer malware from employee devices to bypass authentication on portals where MFA is not enforced. ShareFile, which originated in Florida, is a standard tool for many state engineering and government entities. This campaign demonstrates that "identity trust" failures are as dangerous as software vulnerabilities when organizations fail to secure cloud-based file-sharing environments.

“Russian Hackers Weaponize Microsoft Office Bug in Just 3 Days” On February 3, 2026, researchers confirmed that the Russian state-sponsored group APT28 (Fancy Bear) weaponized a critical Microsoft Office security bypass vulnerability (CVE-2026-21509) just three days after a patch was released. The exploit utilizes specially crafted Rich Text Format (RTF) documents to bypass security mitigations in Microsoft 365 and Office, executing arbitrary code to deploy "MiniDoor" malware. This rapid exploitation cycle targets government and infrastructure sectors globally. Florida organizations are at high risk given the widespread use of Microsoft productivity suites for administrative and operational coordination.

“Notepad++ Infrastructure Hijacked by Chinese APT in Sophisticated Supply Chain Attack” A sophisticated supply chain attack, attributed to a Chinese-nexus Advanced Persistent Threat (APT) group tracked as Lotus Blossom, has compromised the update infrastructure for the Notepad++ coding application. By hijacking the legitimate update mechanism, the attackers distributed a malicious plugin designed to exfiltrate sensitive data from developer systems. This incident mirrors the 2024 XZ Utils compromise and poses a significant risk to Florida’s technology sector where developers frequently utilize this tool. (Note: The Reuters and Security Affairs links are grouped here as duplicate echoes of this incident)

“China-Linked DKnife AitM Framework Targets Routers for Traffic Hijacking” On February 6, 2026, reports identified a new Adversary-in-the-Middle (AitM) framework named "DKnife," attributed to China-linked actors. The framework targets various edge devices, including routers and Internet of Things (IoT) hardware, to hijack binary downloads and mobile application updates. DKnife allows attackers to intercept network traffic and deliver secondary backdoors like ShadowPad to internal workstations.

“Shadow Campaigns: Uncovering Global Espionage Targeting Unmanaged Devices” Technical analysis released on February 9, 2026, details "Shadow Campaigns" conducted by a sophisticated state-aligned actor targeting unmanaged and end-of-life (EOL) edge devices across 155 countries. The threat group exploits known vulnerabilities in internet-facing hardware, such as routers and Network Attached Storage (NAS) devices, to establish persistent backdoors and conduct long-term espionage. These campaigns specifically leverage "living off the land" (LotL) techniques, utilizing legitimate system tools to evade detection by traditional endpoint security. This activity materially changes defensive priorities for Florida’s information technology sector

by highlighting the critical risk posed by unmonitored edge infrastructure and the necessity of decommission schedules for legacy hardware.

“Microsoft February 2026 Patch Tuesday Fixes 6 Zero-Days, 58 Flaws” Microsoft’s February 2026 Patch Tuesday addressed 58 vulnerabilities, including six zero-day flaws being actively exploited in the wild. Key vulnerabilities include CVE-2026-21510, which bypasses Windows Shell security prompts, and CVE-2026-21519, an elevation of privilege flaw in the Desktop Window Manager that allows attackers to gain SYSTEM privileges. These flaws allow for unauthorized code execution and security feature bypasses across all currently supported Windows versions. Given the near-universal use of these tech stacks in Florida's CI business operations, these updates are considered high-priority for maintaining organizational security posture.

“CISA Releases Guide to Help Critical Infrastructure Users Adopt More Secure Communication” On February 10, 2026, the CISA published a guide aimed at transitioning CI operators toward authenticated and encrypted communication protocols. The guidance addresses inherent vulnerabilities in legacy industrial protocols that lack native security features, often leaving systems open to unauthorized command injection or data interception. By providing a roadmap for protocol modernization, the guide helps mitigate risks for Florida's utility and manufacturing facilities, which frequently rely on aged legacy hardware that is now exposed to internet-facing threats.

Information Technology Sector - Recommendations:

- Patch Fortinet devices: Immediately upgrade all FortiOS, FortiManager, and FortiAnalyzer devices to the latest firmware versions to remediate critical authentication bypass vulnerabilities in FortiCloud Single Sign-On (SSO).
- Utilize MFA: Implement hardware-based or FIDO2-compliant MFA across all cloud file-sharing and identity platforms, such as ShareFile and Nextcloud, to prevent credential-based "identity trust" failures.
- Update workstations: Ensure developer workstations and software update mechanisms are secured by validating the integrity of third-party plugins and update repositories for tools like Notepad++.
- Authenticate and encrypt: Transition toward authenticated and encrypted communication protocols as outlined in CISA’s February 2026 guide to mitigate risks from legacy hardware and "Adversary-in-the-Middle" (AitM) frameworks like DKnife.
- Replace EOS devices: Maintain and enforce a rigorous decommissioning schedule for end-of-life (EOL) and unmanaged edge devices to reduce the attack surface for "living off the land" (LotL) espionage campaigns

Nuclear Reactors, Materials, and Waste Sector

No sector-specific incidents, advisories, or tactically relevant reporting were identified during this biweekly reporting period

Transportation Systems Sector

No sector-specific incidents, advisories, or tactically relevant reporting were identified during this biweekly reporting period

Water and Wastewater Systems Sector

“Wichita Water Bill Payments Disrupted by Ransomware Attack” A ransomware attack against third-party payment vendor BridgePay Network Solutions has disabled online credit and debit card water-bill payments for the City of Wichita, Kansas. While city officials report that no payment card data are compromised, the disruption forced residents to utilize alternative payment methods like Automated Clearing House (ACH) or in-person cash payments while federal investigators assess the impact. This incident underscores the cybersecurity risks posed by third-party vendors supporting municipal billing systems, a common dependency for Florida water utilities.

“Multi-Country DDoS Campaign: Weekly DDoS Threat Intelligence Analysis” The pro-Russian group NoName057(16) targeted water utilities in the UK, including Scottish Water and ICOSA Water Services, as part of a broader campaign against NATO members. The attacks utilized the "DDoSia" tool to launch TCP and HTTP floods against port 443 (HTTPS). The campaign aims to disrupt essential services and erode public confidence.

“Senate Hearing Examines Growing Cybersecurity Risks to U.S. Water Systems” A February 4, 2026, U.S. Senate hearing highlighted that 14% of surveyed water utilities experienced at least one cyber incident in the past year, up from 11.5% the year prior. These data are indicative of increased "pre-positioning" by state-sponsored actors like Volt Typhoon and the persistent use of default passwords in small-to-midsized municipal systems. The hearing emphasized that less than 25% of water utilities perform annual cyber risk assessments. For Florida, the high density of small municipal water systems creates a target-rich environment for the low-sophistication, high-impact TTPs discussed.

Water and Wastewater Systems Sector - Recommendations:

- Audit vendors: Implement a formal vendor risk management program to identify and mitigate critical dependencies on third-party payment gateways like BridgePay.
- Utilize firewalls: Deploy web application firewalls and DDoS mitigation services to filter malicious traffic targeting port 443, specifically to counter "DDoSia" and other state-sponsored flood tools.

- Update policies: Enforce a "no default password" policy across all industrial control systems and internet-facing assets, requiring unique, complex credentials for every device.
- Continually assess risk: Conduct annual cyber risk assessments and vulnerability scans as discussed in recent federal testimony to identify state-sponsored "pre-positioning" within the network.
- Practice workarounds: Establish and test manual workarounds for billing and customer service operations to ensure revenue continuity during extended third-party outages.